НАО «КАРАГАНДИНСКИЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ ИМЕНИ АБЫЛКАСА САГИНОВА»

Кафедра Кибербезопасности и искусственного интеллекта

Лабораторная работа № 6

по дисциплине «Безопасность Баз данных»

Тема:«Оценка уязвимостей и классификация данных»

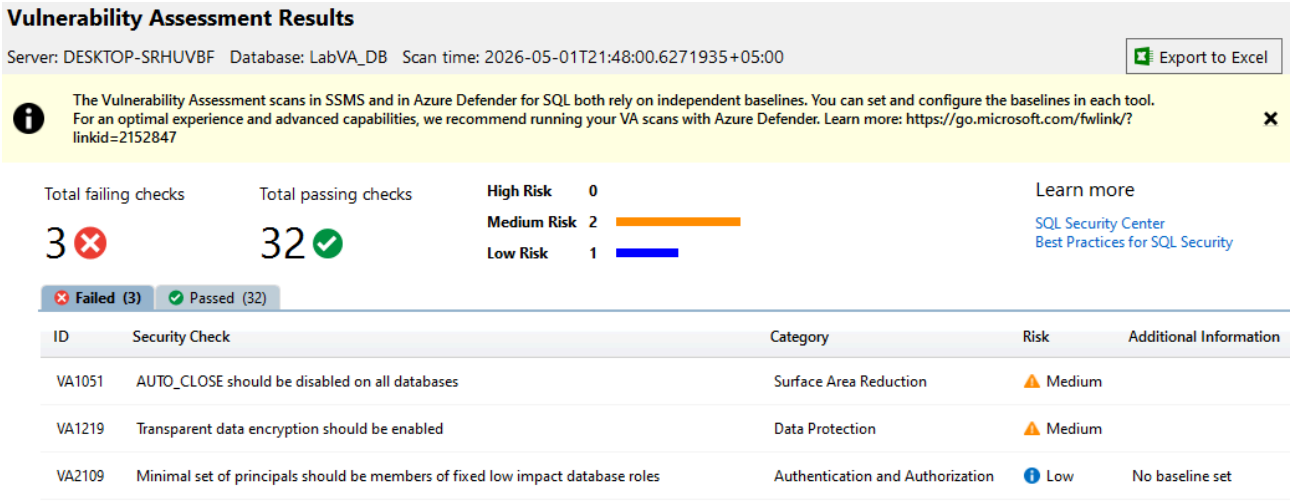
Специальность: 6В06301 – «Системы информационной безопасности»

Принял: ст.преп.
Жакина М.М.
Выполнил:
СИБ 23-7 Гарифуллин И.Р.

Караганда 2026

Задания:

1. Необходимо провести оценку уязвимостей на собственной БД
2. Зафиксируйте общее количество правил и соотношение passed/failed



3. Составьте таблицу всех провальных правил по следующей форме:

ID правила	Уровень риска	Краткое описание	Планируемая мера
VA1051	Medium	The AUTO_CLOSE option specifies whether the database shuts down gracefully and frees resources after the last user disconnects. Regardless of its benefits it can cause denial of service by aggressively opening and closing the database, thus it is important to keep this feature disabled. This rule checks that this option is disabled on the current database.	Отключить параметр AUTO_CLOSE для базы данных командой ALTER DATABASE LabVA_DB SET AUTO_CLOSE OFF;.
VA1219	High	Для базы данных не включено Transparent Data Encryption. Это означает, что файлы базы данных и	Включить TDE: создать master key, сертификат, database encryption key и выполнить ALTER DATABASE LabVA_DB SET ENCRYPTION ON;. Для

		резервные копии не шифруются на уровне хранения. При получении доступа к файлам БД злоумышленник потенциально может прочитать данные.	учебной лабораторной можно указать, что мера запланирована, если используется редакция SQL Server, где TDE недоступен.
VA2109	low	В фиксированных ролях базы данных с низким уровнем влияния находятся лишние пользователи. Обычно это роли вроде db_datareader и db_datawriter. Чем больше пользователей имеют такие роли, тем выше риск избыточного доступа к данным.	Проверить участников ролей db_datareader, db_datawriter, db_denydatareader, db_denydatawriter. Удалить лишних пользователей из этих ролей и выдать только минимально необходимые права.

4. Для каждого провального правила высокого уровня риска выполните рекомендованные меры по устранению

VA1051:

Отключить параметр AUTO_CLOSE для базы данных командой

ALTER DATABASE LabVA_DB SET AUTO_CLOSE OFF;.

VA1219 :

Для правила VA1219 — Transparent data encryption should be enabled была выполнена рекомендованная мера по устранению: попытка включения Transparent Data Encryption для базы данных LabVA_DB. Для этого были созданы необходимые объекты шифрования: master key, сертификат и ключ шифрования базы данных. Однако при выполнении команды включения шифрования SQL Server вернул ошибку Msg 33117, согласно которой Transparent Data Encryption недоступен в используемой редакции SQL Server. Следовательно, устранение данного правила в текущей среде невозможно по техническому ограничению редакции. В качестве планируемой меры требуется использовать редакцию SQL Server, поддерживающую TDE, например

Developer, Enterprise или другую редакцию с поддержкой данной функции, либо выполнить лабораторную на соответствующем экземпляре SQL Server.

VA2109:

```
USE LabVA_DB;
GO
ALTER ROLE db_datareader DROP MEMBER lab_user;
ALTER ROLE db_datawriter DROP MEMBER lab_user;
GO
```

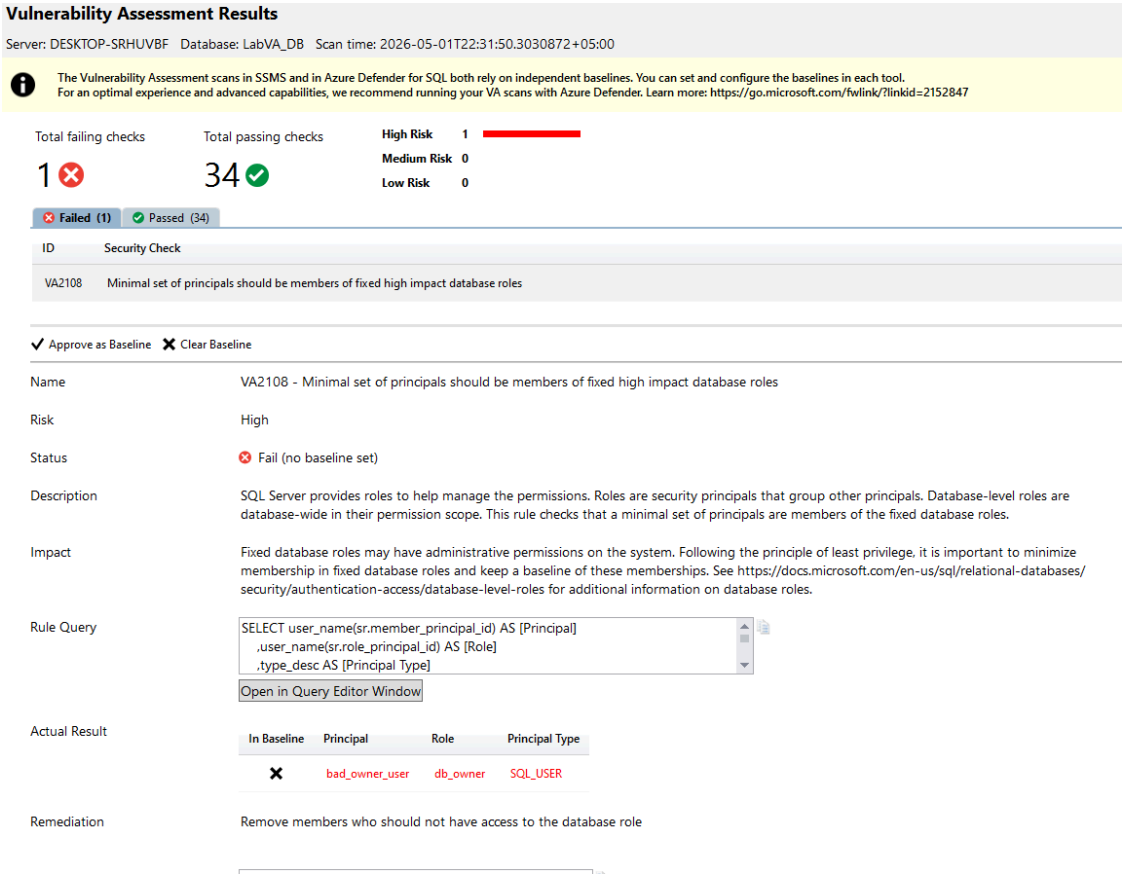
5. Повторно запустите оценку и сравните результаты.

6. Намеренно создайте в базе данных ситуацию, нарушающую одно из правил (например, добавьте пользователя в роль db_owner или создайте учётную запись со слабым паролем)

```
USE master;
GO

CREATE LOGIN bad_owner_user
WITH PASSWORD = 'BadOwner_123!',
CHECK_POLICY = ON;
GO

USE LabVA_DB;
GO

CREATE USER bad_owner_user FOR LOGIN bad_owner_user;
GO

USE LabVA_DB;
GO

ALTER ROLE db_owner ADD MEMBER bad_owner_user;
GO

USE LabVA_DB;
GO

SELECT
```

```
    role_principal.name AS role_name,
    member_principal.name AS member_name,
    member_principal.type_desc AS member_type
FROM sys.database_role_members drm
JOIN sys.database_principals role_principal
    ON drm.role_principal_id = role_principal.principal_id
JOIN sys.database_principals member_principal
    ON drm.member_principal_id = member_principal.principal_id
WHERE role_principal.name = 'db_owner';
```

7. Повторно запустите оценку и убедитесь, что новое нарушение зафиксировано



Контрольные вопросы:

1. Уязвимость — это слабое место в базе данных, которое можно использовать для нарушения безопасности. Угроза — это потенциальная опасность, которая может воспользоваться уязвимостью. Инцидент — это уже произошедший случай нарушения.

2. Основные категории: ошибки конфигурации (например, включённый доступ для всех), слабая аутентификация (простой пароль), избыточные права (пользователь с правами администратора без необходимости), уязвимости кода (SQL-инъекции).

3. CVSS — это система оценки уровня опасности уязвимости. Учитывает базовые параметры (насколько легко атаковать), временные (есть ли эксплойты), и контекстные (важность системы).

4. Принцип наименьших привилегий — пользователь должен иметь только те права, которые ему нужны. Если прав больше, чем нужно, это увеличивает риск взлома или ошибок.

5. Плюсы: быстро, автоматически проверяет много параметров, находит типовые ошибки, удобно для регулярного контроля.

6. Минусы: не видит контекст, не понимает бизнес-логику, может давать ложные срабатывания. Поэтому не заменяет ручную проверку.

7. Эффективна при регулярных проверках, первичном анализе безопасности и поиске типовых уязвимостей.

8. Правила основаны на рекомендациях безопасности Microsoft, стандартах и лучших практиках настройки SQL Server.

9. Правило состоит из: идентификатора, описания проблемы, уровня риска и рекомендации по исправлению.

10. Baseline — это зафиксированное допустимое состояние. Используется, когда найденная «уязвимость» на самом деле допустима и не требует исправления.

11. В системных базах проверяются критичные настройки сервера, в пользовательских — права доступа, роли и данные.

12. Это правило проверяет избыточные права. Высокий риск, потому что даёт возможность получить полный контроль над базой.

13. Это означает «считать это нормой». Риск — можно случайно принять настоящую уязвимость и пропустить проблему.

14. Классификация данных — это определение уровня важности данных (например, персональные данные). Нужна для защиты и соблюдения требований безопасности.

15. SQL Server использует названия столбцов, типы данных, шаблоны (например email, ИИН, номера карт). Да, можно добавлять свои правила и метки.

16. Метки: Public, General, Confidential, Highly Confidential.

17. GDPR — это закон ЕС о защите персональных данных. Он требует находить и защищать такие данные, поэтому напрямую связан с классификацией.

18. Оценка уязвимостей и классификация связаны через защиту чувствительных данных. Объединяющее правило — проверка наличия защиты (например шифрования) для конфиденциальных данных.

19. Потому что она работает по шаблонам и не понимает смысл данных. Часто пропускает нестандартные названия и данные, скрытые в тексте.

20. По ним можно настроить аудит доступа к важным данным и включить шифрование именно для чувствительных столбцов.

21. Сначала исправить все с высоким риском, затем средние, потом низкие. После этого повторно проверить систему.

22. Это скрывает реальные проблемы. Я бы не согласился и предложил исправить хотя бы критические уязвимости.

23. Устранение — это исправление проблемы. Baseline — это признание, что это допустимо. Второй вариант допустим, если это осознанное и безопасное решение.

24. Они помогают понять слабые места и расставить приоритеты по защите, чтобы построить план повышения безопасности.